TECNOLOGÍA EN DESARROLLO DE SOFTWARE

PROYECTO ASISTENTEIA

MATRIZ DE RIESGOS

Seguridad, privacidad y uso responsable

Elaborado por	Juan Esteban Olaya Muñoz
Programa	Tecnología en Desarrollo de Software
Producto	Seguridad, privacidad y uso responsable
Fecha	23/10/2026

Escala: probabilidad e impacto Baja/Media/Alta; nivel = combinación cualitativa.

ID	Riesgo	Prob.	Impacto	Nivel	Mitigación	Residual
R-01	Filtración de la API key	Media	Alto	Alto	SecureStorage; clave nunca en código/SQLite/Preferences/logs/Git; campo oculto; botón Eliminar clave; .gitignore.	Medio
R-02	Dispositivo comprometido o con root	Baja	Alto	Medio	SecureStorage no impide la extracción en un dispositivo comprometido; usar claves con cuota/gasto limitado y revocarlas.	Medio
R-03	Pérdida de privacidad (prompts enviados a un tercero)	Alta	Medio	Alto	Aviso al usuario; el proveedor es elegido explícitamente; no se envían datos a terceros adicionales.	Medio
R-04	Prompts con datos personales	Media	Alto	Alto	Advertir en manual de usuario; no registrar prompts en logs; historial solo local.	Medio
R-05	Respuestas inventadas o incorrectas	Alta	Medio	Alto	Aviso en pantalla; campo IsVerified para marcar verificación manual.	Medio
R-06	Contenido dañino o inapropiado	Baja	Medio	Medio	Depende de los filtros del proveedor; el usuario puede eliminar registros.	Bajo
R-07	Dependencia del proveedor (caída, cambios de API)	Media	Medio	Medio	Capa IAiClient/catálogo; la UI sigue usable sin proveedor; modelos cargados dinámicamente.	Bajo
R-08	Límites de uso y costos (429, créditos)	Media	Medio	Medio	Mensaje 429 claro; sin reintentos automáticos; validación de 1 token; modelos paid_only identificables.	Bajo
R-09	Pérdida o corrupción del historial	Baja	Medio	Bajo	SQLite transaccional; operaciones con manejo de errores; no hay copia de seguridad automática (pendiente).	Bajo
R-10	Vulnerabilidades en dependencias nativas (SQLite)	Media	Alto	Alto	Paquetes e_sqlite3 fijados en 2.1.14; revisar con dotnet list package --vulnerable.	Bajo
R-12	Clave expuesta fuera de la app (capturas, historial de comandos, mensajes) durante pruebas	Media	Alto	Alto	No guardar claves en archivos ni commits (verificado con búsqueda en el repo); pasar la clave por variable de entorno temporal; revocar y regenerar la clave usada en pruebas.	Bajo tras revocar
R-13	Modelos retirados o renombrados por el proveedor	Alta	Bajo	Medio	Modelo por defecto verificado; catálogo cargable desde el proveedor; error 404 con mensaje claro.	Bajo
R-11	Copia de seguridad de Android con clave cifrada ilegible	Baja	Bajo	Bajo	MauiSecretStore captura el error de descifrado y trata la clave como ausente.	Bajo

Limitación de seguridad móvil

SecureStorage protege la clave almacenada en el dispositivo, pero no puede hacer imposible su extracción en un dispositivo comprometido, ni convierte una clave embebida en la app en un secreto de servidor. Por eso AsistenteIA no incluye ninguna clave predeterminada: el usuario introduce la suya.